

REST API Design Best Practices

Subject: Web Development Topic: Node.js

Overview

Resource naming, HTTP methods, status codes, versioning, pagination

Resources and methods

- Model URLs as nouns such as /notes and /notes/{id}; use HTTP methods to describe the operation.
- GET reads, POST creates or triggers a subordinate action, PUT replaces, PATCH partially updates, and DELETE removes.
- Keep representations consistent and return the created resource with 201 Created when useful.

Status codes and errors

- Use 200 for successful reads or updates, 201 for creation, 204 for success without a body, and 400 for invalid input.
- Use 401 for unauthenticated requests, 403 for forbidden actions, 404 for missing resources, and 409 for conflicts.
- Return a stable error shape with a clear message; do not expose stack traces or secrets to clients.

Validation and security

- Validate identifiers, body fields, query parameters, file sizes, and uploaded content on the server.
- Enforce authorization for each resource, not just for a route group; never trust a client-supplied owner or role.
- Use HTTPS in production, secure cookies or tokens, rate limits for sensitive endpoints, and safe output handling.

Pagination and operations

- Use bounded pagination and return total or next-page metadata; reject invalid or excessive limits.
- Allowlist sortable fields and filter parameters rather than passing arbitrary client keys to database operations.
- Document endpoints, request and response shapes, authentication, and expected error codes; log request IDs without logging credentials.